CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: PhishStrike (CyberDefenders)

Investigación de phishing e inteligencia de amenazas: desde el análisis de cabeceras hasta la identificación de persistencia y canales C2, extrayendo Indicadores de Compromiso (IoCs) accionables.

Sebastian David
Torres Reyes

Escenario:

Como analista de ciberseguridad en una institución educativa, recibe una alerta sobre un correo electrónico de phishing dirigido a profesores. El correo electrónico parece provenir de un contacto de confianza y afirma una compra de 625.000 dólares, además de proporcionar un enlace para descargar una factura.

Su tarea consiste en investigar el correo electrónico con herramientas de inteligencia de amenazas. Analice los encabezados del correo electrónico e inspeccione el enlace en busca de contenido malicioso. Identifique cualquier indicador de compromiso (IOC) y documente sus hallazgos para prevenir posibles fraudes y educar al profesorado sobre cómo reconocer el phishing.

Herramientas utilizadas:

- Email Header Analyzer
- URLHaus
- VirusTotal
- MalwareBazaar
- VMRay
- CyberChef
- Tria.ge

Resumen:

El incidente analizado detalla una campaña de spear-phishing dirigida a docentes, utilizando un señuelo financiero para inducir la descarga de un 'loader' malicioso. Tras utilizar comandos de PowerShell para evadir entornos de sandbox, el código estableció persistencia en el Registro de Windows y facilitó la descarga y ejecución automática de una de tres familias de malware (BitRAT, AsyncRAT o CoinMiner), dependiendo de la rotación definida por el atacante. El impacto final varió según el payload distribuido, permitiendo desde el control total del sistema y el uso de CPU/GPU para minería de criptomonedas, hasta la exfiltración de datos utilizando infraestructura C2 dedicada (162.191.38.27) y un bot de Telegram (ID: bot5610920260).

P1: Identificar la dirección IP del remitente con valores SPF y DKIM específicos ayuda a rastrear el origen del correo electrónico de phishing. ¿Cuál es la dirección IP del remitente con un valor SPF de softfail y un valor DKIM de fail?

R: 18.208.22.104

Para analizar el encabezado del correo electrónico se usó la herramienta Email Header Analyzer y se encontró que la dirección IP del remitente es 18.208.22.104. También se verificó el valor SPF de softfail y el valor DKIM de fail.

Headers Found

Header Name	Header Value
ARC-Seal	i=2; a=rsa-sha256; s=arcselector9901; d=microsoft.com; cv=fail; b=duSdPQF6MkHA6NDKezdwwXo0cytNw6pKTyXfmDvi22cwiu15XbtSLWvmqSHiYcaOHDQNUg5f7tY+9JY/CEBHmaBO7E3lusTGIpLFNrNF7v4HyOwH2/XWf+JxNDSUM3TE24w0u8DhCnVy2lAoiH/iINzpcewzwrIQWVvKXkhk8UGbOf4SIgEJfiv9JrrQVPUqI0wysWGU3gqoduOgIbFvpjyyGiS/Exd9ddgnfa0sS+83SRQg3jVmLEfSVcmg+9wvZfR6wFcX9Sga7efMqt6a9hT0q3ajrVBYuH+sY2EI9UVvViZREf/FBYYkzJ8xO5oLFQanthp6EoFyN/DqNgO2Tw==
ARC-Message-Signature	i=2; a=rsa-sha256; c=relaxed/relaxed; d=microsoft.com; s=arcselector9901; h=From:Date:Subject:Message-ID:Content-Type:MIME-Version:X-MS-Exchange-AntiSpam-MessageData-ChunkCount:X-MS-Exchange-AntiSpam-MessageData-0:X-MS-Exchange-AntiSpam-MessageData-1; bh=AXBCwGkRxYZo4VpdXt4XQsGpZAHIDSpANJ7sP0OmP3M=; b=YV4rXtkEs8amVnLpcgziiiy3nO93s3HgMRy5SCHjk2Hw+yNPHRtJ2XWmWhSPI6W5aaIFstGBWpjyhE0u9A3vzC9r7ooUojm+hWE3Np2Kr2RyqtHrGzRQkzlGQ51vzG1U7jFokrXN0bUcIFoXMlhZMvIoATxCZfj+TpT/zyoVxok1bxb1fyul8TWqqvPVFWO3lB38fuZ7QXcLCoc0GwVELhF8RfiHlEqiyS8u5emyOlJOSZBO1RniGFcZ+eDvGfM9bSui8daMiifi7VvoaMX0+ed6ajqa1zsBzWOD4BfGyVSgD5udi6wtnzcTKcqDJo9JyTfocwmCR8FIhINRFo0CcQ==
ARC-Authentication-Results	i=2; mx.microsoft.com 1; spf=softfail (sender ip is 18.208.22.104) smtp.rcpttodomain=fsfb.org.co smtp.mailfrom=uptc.edu.co; dmarc=none action=none header.from=uptc.edu.co; dkim=fail (no key for signature) header.d=uptc.edu.co; arc=fail (35)
Authentication-Results	spf=softfail (sender IP is 18.208.22.104) smtp.mailfrom=uptc.edu.co; dkim=fail (no key for signature) header.d=uptc.edu.co;dmarc=none action=none header.from=uptc.edu.co;compauth=softpass reason=201
Received-SPF	SoftFail (protection.outlook.com: domain of transitioning uptc.edu.co discourages use of 18.208.22.104 as permitted sender)

P2: Comprender la ruta de retorno de un correo electrónico es esencial para rastrear su origen. ¿Cuál es la ruta de retorno especificada en este correo electrónico?

R: erikajohana.lopez@uptc.edu.co

El correo electrónico de retorno identificado en el encabezado es erikajohana.lopez@uptc.edu.co.

X-TM-Addin-ProductCode	EMS
Return-Path	erikajohana.lopez@uptc.edu.co
X-MS-Exchange-Organization-ExpirationStartTime	9 Dec 2022 14:58:42.2762 (UTC)

P3: Identificar el origen del malware es fundamental para mitigar y responder eficazmente ante amenazas. ¿Cuál es la dirección IP del servidor que aloja el archivo malicioso relacionado con la distribución del malware?

R: 107.175.247.199

Al examinar el contenido del correo se pudo visualizar el enlace de descarga del archivo malicioso que simula la descarga de la factura. El servidor que almacena este archivo malicioso es 107.175.247.199.

```
COMMERCIAL PURCHASE RECEIPT

Your purchase Ref. 00034959 for the amount of $625.000 pesos has been successfully completed. The invoice document is attached for your full confirmation.

VIEW INVOICE DOCUMENT HERE
<http://107.175.247.199/loader/install.exe>
ACCESS CODE: 8657

Erika Johana López Valiente
Magister in Education, Research Mode.
LEB Teacher - FESAD.

CONFIDENTIALITY NOTICE: This message and its attachments are intended exclusively for its addressee. It may contain privileged or confidential information and is for
```

P4: Identificar malware que explota los recursos del sistema para minar criptomonedas es fundamental para priorizar las medidas de mitigación de amenazas. La URL maliciosa puede distribuir varios tipos de malware. ¿Qué familia de malware es responsable de la minería de criptomonedas?

R: CoinMiner

Se usó la herramienta URLHaus para buscar los dominios relacionados a la dirección IP del servidor que almacena el ejecutable malicioso con el objetivo de encontrar la URL investigada.

Dateadded (UTC)	Malware URL	Status	Tags	Reporter
2025-08-06 18:27:34	http://107.175.247.199:8657	Offline		meherin
2025-04-04 08:59:32	http://107.175.247.199//loader//install.exe	Offline		kynhvc
2022-10-22 12:39:04	http://107.175.247.199/loader/install.exe	Offline	AsyncRAT bitrat CoinMiner	abuse_ch
2022-10-22 06:36:06	http://107.175.247.199/loader/Rckjlz.exe	Offline	exe PureCrypter	abuse_ch
2022-10-22 06:35:08	http://107.175.247.199/loader/server.exe	Offline	bitrat exe	abuse_ch

Se pudo encontrar que la familia del malware responsable de la minería de criptomonedas fue CoinMiner.

ID:	2381718
URL:	http://107.175.247.199/loader/install.exe
URL Status:	Offline
Host:	107.175.247.199
Date added:	2022-10-22 12:39:04 UTC
Last online:	2022-12-12 07:XX:XX UTC
Threat:	Malware download
Reporter:	abuse_ch
Abuse complaint sent (?):	Yes (2022-10-22 12:40:12 UTC to abuse(at)hudsonvalleyhost[dot]com)
Takedown time:	1 month, 20 days, 18 hours, 19 minutes (down since 2022-12-12 07:00:08 UTC)
Tags:	AsyncRAT bitrat CoinMiner

P5: Identificar las URL específicas que solicita el malware es clave para interrumpir sus canales de comunicación y reducir su impacto. Según el análisis previo de la muestra de malware de criptomonedas, ¿qué URL solicita este malware?

R: http://ripley.studio/loader/uploads/Qanjttrbv.jpeg

Para identificar las URL específicas que solicita el malware de criptomonedas se necesitó el hash SHA256 perteneciente que URLHaus proporcionó.

Payload delivery

The table below documents all payloads that URLhaus retrieved from this particular URL.

Firstseen	Filename	File Type	Payload (SHA256)	VT	Bazaar	Signature
2022-10-26	n/a	exe	bf7628695c2df7a3020034a065397592a1f8850e59f9a448b555bc1c8c639539	n/a		BitRAT
2022-10-25	n/a	exe	5ca468704e7ccb8e1b37c0f7595c54df4e2f4035345b6e442e8bd4e11c58f791	n/a		AsyncRAT
2022-10-22	n/a	exe	453fb1c4b3b48361fa8a67dcedf1eaec39449cb5a146a7770c63d1dc0d7562f0	n/a		CoinMiner

Posteriormente, haciendo uso del hash, se utilizó VirusTotal para su análisis. Se identificaron las URL contactadas por el malware:

- http://ripley.studio/loader/uploads/Qanjttrbv.jpeg
- http://107.175.247.199/loader/server.exe.

453fb1c4b3b48361fa8a67dcedf1eaec39449cb5a146a7770c63d1dc0d7562f0

Contacted URLs (2)

Scanned	Detections	Status	URL
2026-03-11	9 / 95	-	http://ripley.studio/loader/uploads/Qanjttrbv.jpeg
2025-08-09	11 / 97	-	http://107.175.247.199/loader/server.exe

P6: Comprender las entradas de registro que el malware añade a la clave de ejecución automática es crucial para identificar sus mecanismos de persistencia. Según el análisis de la muestra de malware BitRAT, ¿cuál es el nombre del ejecutable en el primer valor añadido a la clave de ejecución automática del registro?

R: Jzwvix.exe

Esta técnica de persistencia consiste en añadir entradas en las claves de registro de Windows con el objetivo de que los cambios agregados sean reconocidos como legítimos por Windows.

Se encontró que se agregó una entrada en la clave "HKEY_CURRENT_USER\Software\Microsoft\Installer\Assemblies\" del ejecutable Jzwvix.exe con la finalidad de que se instale silenciosa y formalmente en el sistema y garantizar su persistencia.

```
HKEY_CURRENT_USER\Software\Microsoft\Fusion
HKEY_CURRENT_USER\Software\Microsoft\Installer\Assemblies\C:|Users|user|AppData|Roaming|Ozndcoodb|Jzwvix.exe
HKEY_CURRENT_USER\Software\Microsoft\Installer\Assemblies\C:|Users|user|Desktop|software.exe
```

Finalmente, se agregó el mismo ejecutable como entrada en la clave "HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run", clave encargada de la ejecución automática legítima.

Details | Related VTIs (1)

Registry Key	HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run\Jzwvix
Registry Key Type	REG_NONE
Operations	access, write, read
Related Process Names	bf7628695c2df7a3020034a065397592a1f8850e59f9a448b555bc1c8c639539.exe
Related Process Comm and Lines	"C:\Users\RDhJ0CNFevzX\Desktop\bf7628695c2df7a3020034a065397592a1f8850e59f9a448b555bc1c8c639539.exe"
Verdict	CLEAN

P7: Identificar el hash SHA-256 de los archivos descargados de una URL maliciosa es esencial para rastrear y analizar la actividad de malware. Según el análisis de BitRAT, ¿cuál es el hash SHA-256 del archivo previamente descargado y añadido a las claves de ejecución automática?

R: bf7628695c2df7a3020034a065397592a1f8850e59f9a448b555bc1c8c639539

El ejecutable malicioso BitRAT es reconocido por VirusTotal por el nombre Jzwvix.exe entre otros nombres. El SHA-256 de Jzwvix.exe es el mismo de la muestra de malware BitRAT proporcionada por URLHaus.

Names

bf7628695c2df7a3020034a065397592a1f8850e59f9a448b555bc1c8c639539.exe
install.exe
unknown
xSzQcEkCtN
Jzwvix.exe

P8: Analizar las solicitudes HTTP realizadas por el malware ayuda a identificar sus patrones de comunicación. ¿Cuál es la URL de la solicitud HTTP que utiliza el loader para recuperar el malware BitRAT?

R: http://107.175.247.199/loader/server.exe

La solicitud HTTP realizada por el loader para recuperar el malware BitRAT es http://107.175.247.199/loader/server.exe.

Contacted URLs (2)

Scanned	Detections	Status	URL
2022-11-01	15 / 90	200	http://ripley.studio/loader/uploads/Hjvnp.png
2025-08-09	11 / 97	-	http://107.175.247.199/loader/server.exe

P9: Introducir un retraso en la ejecución del malware puede ayudar a evadir los mecanismos de detección. ¿Cuál es el retraso (en segundos) causado por el comando de PowerShell según el análisis de BitRAT?

R: 50

Para manejar y analizar mejor el malware BitRAT ingresó el hash SHA-256 en MalwareBazaar con el objetivo de obtener los reportes del malware de distintos proveedores de inteligencia de amenazas (VMRay, Any.run, VirusTotal, etc).

Threatray malicious	+
Hatching Triage bitrat	+
Threat.Zone Malicious	+
UnpacMe PureCrypter Stage1	+
VMRay Malicious	+
VirusTotal	+
YOROI YOMI Suspicious File	+

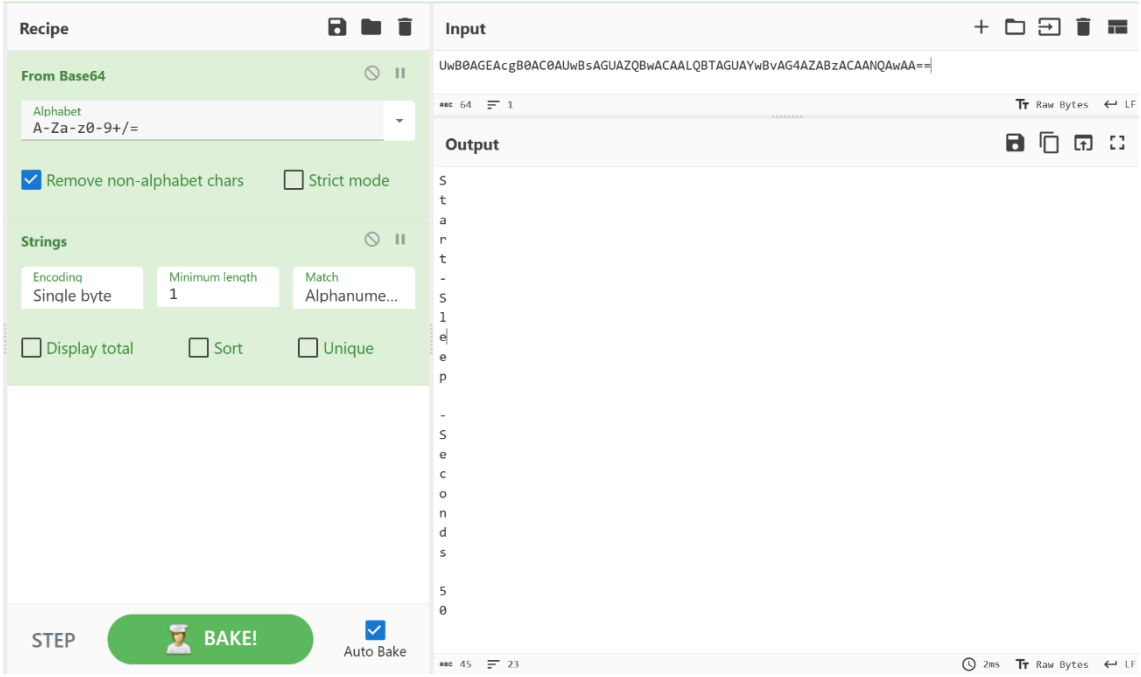
Para identificar el comportamiento del malware en ejecución se escogió un proveedor de reportes de análisis dinámico, en este caso VMRay.

En el segundo proceso del malware se encontró un ejecutable powershell.exe y se identificó el parámetro "-enc" que es utilizado para la ejecución de comandos codificados en base64.

Process #2: powershell.exe 416 0

Information	Value
ID	#2
File Name	c:\windows\syswow64\windowspowershell\v1.0\powershell.exe
Command Line	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -enc UwB0AGEAcgB0AC0AUwBsAGUAZQBwACA ALQBTAGUAYwBvAG4AZABzACAANQAwAA==
Initial Working Directory	C:\Users\RDhJ0CNFevzX\Desktop\
Monitor	Start Time: 00:01:51, Reason: Child Process
Unmonitor	End Time: 00:03:33, Reason: Terminated
Monitor Duration	00:01:42
Return Code	0

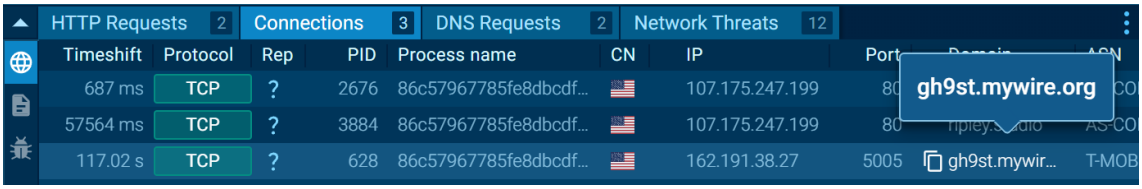
Se decodificó la cadena de texto con la herramienta CyberChef. Como resultado se obtuvo la cadena en texto legible "Start-Sleep-Seconds 50", por ende, se determinó que el retraso introducido es de 50 segundos. La finalidad de este retraso es el Anti-Sandboxing.



P10: El seguimiento de los dominios de comando y control (C2) utilizados por el malware es esencial para detectar y bloquear actividades maliciosas. ¿Cuál es el dominio C2 utilizado por el malware BitRAT?

R: gh9st.mywire.org

Se analizó el reporte dado por Any.run y se encontraron 2 direcciones IP contactadas. La primera dirección IP 107.175.247.199 de dominio ripley.studio encargada de alojar el archivo malicioso y la segunda dirección IP 162.191.38.27 de dominio gh9st.mywire.org que es el dominio C2 utilizado por el malware BitRAT.



P11: Comprender cómo el malware exfiltra datos es esencial para detectar y prevenir filtraciones de datos. Según el análisis de AsyncRAT, ¿cuál es el ID del bot de Telegram que utiliza este malware?

R: bot5610920260

Se ingresó el hash de AsyncRat en Tria.ge y se encontró que en las solicitudes HTTP GET se realizó una llamada a la API de un bot de Telegram. El ID de este bot fue bot5610920260.